a. Covered Institutions' Incident Response Program Obligations Regarding Service Providers

In a change from the proposed rule, the Commission is adopting the final amendments without requiring covered institutions to enter into a written contract with their service providers.[220] Instead, the final amendments require that a covered institution's incident response program "include the establishment, maintenance, and enforcement of written policies and procedures reasonably designed to require oversight, including through due diligence and monitoring, of the covered institution's service providers, including to ensure that the covered institution notifies affected individuals as set forth in paragraph (a)(4)," in the event of a breach at the service provider.[221] Further, while the final amendments do not require covered institutions to enter into a written contract, the final amendments incorporate the protections that would have been required in the proposed written contract[222] by requiring that a covered institution's policies and procedures be reasonably designed to ensure service providers take the appropriate measures to: (A) protect against unauthorized access to or use of customer information, and (B) provide notification to the covered institution in the event of a breach resulting in unauthorized access to a customer information system maintained by the service provider, in accordance with the timing

---

discussion on clarifying modifications. *See also* proposed rule 248.30(e)(10).

220 *See* proposed rule 248.30(b)(5)(i). *See also supra* footnote 213 and accompanying discussion.

221 *See* final rule 248.30(a)(5)(i). In the Proposing Release, we requested comment on whether the proposed written contract requirement should instead require that a covered institution adopt policies and procedures that "require due diligence of or some type of reasonable assurances from its service providers." *See* Proposing Release at section II.A.3. We also encouraged commenters to review our separate proposal to prohibit registered investment advisers from outsourcing certain services or functions without first meeting minimum due diligence and monitoring requirements to determine whether that proposal might affect their comments on the Proposing Release. *See* Proposing Release at section G.2, n.300; *see also* Outsourcing by Investment Advisers, Investment Advisers Act Release No. 6176 (Oct. 26, 2022) [87 FR 68816 (Nov. 16, 2022)]. The due diligence standards we are adopting are intended to address related concerns raised by commenters who requested that we adopt a more principles-based set of requirements.

222 *See supra* footnote 213 and accompanying discussion of the substantive obligations that were included in the proposal's written contract requirement.

and notice trigger conditions discussed further below. Finally, in a modification from the proposal, upon receipt of such notification, a covered institution must initiate its incident response program adopted pursuant to paragraph (a)(3) of this section.[223]

Two commenters expressed varying degrees of support for requiring a written contract between a covered institution and its service providers.[224] One such commenter expressed support for requiring a specific contractual agreement with a service provider, stating that the information covered by the service provider provision is already subject to a contractual agreement between the covered institution and the service provider.[225] The other commenter agreed that service providers should be contractually required to take appropriate risk-based measures and due diligence to protect against unauthorized access to or use of customer information, but suggested that for flexibility in oversight covered institutions should be permitted to rely on "reasonable assurances" from service providers that they have taken appropriate measures to protect customer information.[226]

Several commenters opposed this proposed requirement.[227] Specifically, two commenters asserted that the written contract requirement would harm covered institutions, which may not

---

223 *See* final rule 248.30(a)(5)(i).

224 *See* ICI Comment Letter. While this commenter supported a written contract requirement, it did assert that the Commission should adopt a longer compliance period due to the necessity of renegotiating existing contracts with service providers to align the breach notification provisions in those contracts to the rule's requirements. This comment is separately addressed below. *See also* SIFMA Comment Letter 2.

225 *See* ICI Comment Letter. Specifically, this commenter stated that the information that is covered by proposed rule 248.30(b)(5) "is already subject to a contractual agreement between the covered institution and the service provider." *Id.* This commenter further explained it is opposing the contractual requirement because of its very narrow scope, specifically stating that "as drafted, [the requirement] would only apply to any service provider that receives, maintains, processes, or otherwise is permitted access to customer information through the service provider's provision of services directly to the covered institution." *Id.*

226 *See* SIFMA Comment Letter 2.

227 *See*, *e.g.*, AWS Comment Letter; IAA Comment Letter 1 (stating that [covered institutions] should not be required to enter into written agreements with service providers); Google Comment Letter; STA Comment Letter 2; and CAI Comment Letter (stating that many leading service providers (such as cloud service

have the negotiating power or leverage to demand specific contractual provisions from large third-party service providers, particularly where specific provisions are "inconsistent with the business imperatives" of the service provider and/or in the case of small covered institutions.[228] A number of commenters also suggested alternatives to either adopting a written contract requirement or, if such a requirement is adopted, to mandating specified contractual requirements.[229] Two commenters suggested that rather than requiring specific practices to be included within a written contract, the Commission should structure the final amendments to enable covered institutions to take a risk-based approach to due diligence and third-party risk management that integrates reliance on independent certifications, attestations, and industry standards as a sufficient means of assessing and determining whether the service provider is appropriately addressing these risks to an adequate standard.[230] Meanwhile, another commenter who opposed the contractual requirement suggested the Commission should provide covered institutions with the flexibility to oversee their service providers "based on the nature and size of their businesses and in light of the risks posed by the facts and circumstances."[231] Finally, one

---

providers) do not negotiate the standard terms of their services with customers and those standard terms generally would not meet the proposed contractual requirements).

228 *See* IAA Comment Letter 2; *see also* STA Comment Letter 2.

229 *See* SIFMA Comment Letter 2; AWS Comment Letter; Google Comment Letter; and IAA Comment Letter 1.

230 *See* AWS Comment Letter (suggesting that in order to address the practical difficulties of compliance, the Commission should provide covered institutions with a flexible approach to achieving compliance with the service provider provisions that relies on the use of independent certifications, attestations, and adherence to industry standards); *see also* Google Comment Letter (suggesting that rather than prescribing the specific practices that must be included in the contract, (a) contracts should require service providers to implement and maintain appropriate measures that are consistent with industry standards, and (b) each covered entity should oversee its providers to assess if the provider addresses the relevant practices to an adequate standard—noting this activity can be supported with third party certifications and standards).

231 *See* IAA Comment Letter 1.

commenter suggested that it was unclear how a third-party service provider's notice to a covered institution would affect a covered institution's own obligations.[232]

Eliminating the written contract requirement from the final amendments, while enhancing the policies and procedures obligation, strikes an appropriate balance between providing covered institutions with greater flexibility in achieving compliance with the requirements of this rule within the context of their service provider relationships, while also helping to ensure the investor protections afforded by the final amendments are maintained when covered institutions utilize service providers.

In particular, as adopted, the enhanced policies and procedures obligations will enable covered institutions to identify and utilize the most appropriate means for their business of achieving compliance with the final amendments through policies and procedures reasonably designed to require oversight, including through due diligence and monitoring, of their service providers. Providing this flexibility will help address commenters' concerns about imposing a written contractual agreement for covered institutions, particularly those that are small entities, which may not have sufficient negotiating power or leverage to demand specific contractual provisions from a large third-party service provider. At the same time, the enhanced policies and procedures requirements will provide for effective safeguarding of customer information when it is received, maintained, processed, or otherwise accessed by a service provider, as well as timely notice to customers affected by a breach at a covered institution's service provider, by requiring that the policies and procedures be reasonably designed to: (1) require oversight, including through due diligence and monitoring, of service providers, including to ensure that the covered institution notifies affected individuals as required in paragraph (a)(4) and (2) ensure service

---

232 *See* ACLI Comment Letter.

providers take appropriate measures to protect against the unauthorized access to or use of customer information and provide covered institutions with timely notification of a breach so that the covered institution can carry out their incident response program.

While the final amendments thus provide increased flexibility as to a covered institution's means of overseeing its service providers, the modification the Commission is making at adoption does not lower the standard of a covered institution's substantive oversight obligations. Some covered institutions may find that such oversight can be accomplished more easily and less expensively through less formal arrangements in certain circumstances, based on the covered institution's relationship with its service provider, as well as the scope of the services that are now or will be provided over the course of the relationship.[233] However, regardless of the means and arrangements employed, the covered institution must ensure that any service provider it decides to utilize takes appropriate measures to (A) protect against unauthorized access to or use of customer information, and (B) provide breach notifications to the covered institution as required by these final amendments.

Further, while it may be helpful to a covered institution in achieving compliance with the final amendments to receive "reasonable assurances" from its service providers that they have taken appropriate measures to both protect customer information and provide timely notification to the covered institution in the event of a relevant breach of the service provider's customer information systems, reliance solely on such assurances may be insufficient depending on the facts and circumstances, for example when a covered institution knows, or has reason to know, that such assurance is inaccurate. Instead, the final rules require the establishment, maintenance,

---

[233] Although a written contract is not required under the final amendments, covered institutions should generally consider whether a written contract that memorializes the expectations of both covered institutions and their service providers is appropriate.

and enforcement of written policies and procedures reasonably designed to require oversight, including through due diligence and monitoring, of the service provider to ensure the covered institution will be able to satisfy the obligations of paragraph (a)(4). Further, covered institutions generally should consider reviewing and updating these policies and procedures periodically throughout their relationship with a service provider, including updates designed to address any information learned during the course of their monitoring.

The final amendments provide covered institutions with flexibility in overseeing their service provider relationships, while helping to ensure the additional investor protections intended by these final amendments are still achieved. Consistent with this risk-based approach, covered institutions may wish to consider employing such tools as independent certifications and attestations obtained from the service provider, as suggested by some commenters, as part of their policies and procedures to require oversight, including through due diligence and monitoring, of the service provider. However, the covered institution's written policies and procedures must be reasonably designed under the circumstances, and the covered institution's oversight of its service providers pursuant to those written policies and procedures generally should be tailored to the facts and circumstances of the two parties' relationship, which may or may not include the use of such tools.

Further, as stated above, we are modifying the proposed rule to state that upon a covered institution's receipt of a service provider's notification, the covered institution must initiate its incident response program required by paragraph (a)(3) of the rule.[234] The Commission is adopting this modification in response to comment requesting clarification of a covered

[234] *See* final rule 248.30(a)(5)(i).

institution's obligations upon receipt of service provider breach notifications.[235] Further, this modification helps further align the final amendments with the intended purpose of the service provider's breach notifications, as discussed in the Proposing Release.[236] While receipt of such notice automatically triggers the covered institution's obligation to initiate the procedures of its incident response program, such notice is not a necessary predicate to trigger this obligation for incidents occurring at the service provider. A covered institution also must initiate its incident response program where the covered institution has otherwise independently detected an incident of unauthorized access to or use of customer information at the service provider.[237]

Finally, some commenters asked that we consider making any new obligations with respect to a written contract requirement forward-looking so as not to disrupt contracts already in existence by requiring renegotiation, and that we should further extend the compliance date to address this.[238] As we are adopting the rule without a written contract requirement, these comments have become moot.[239]

b. Deadline for Service Provider Notice to Covered Institutions and Notice Trigger

As described above, the final amendments require that a covered institution's policies and procedures be reasonably designed to ensure service providers take appropriate measures to provide covered institutions with notice "as soon as possible, but no later than 72 hours after

---

235 *See* ACLI Comment Letter.

236 This modification is consistent with the intended purpose of this notification, as discussed in the Proposing Release. *See* Proposing Release at Section II.A.3 stating that the purpose of breach notifications to be provided by service providers to a covered institution is "to enable the covered institution to implement its incident response program expeditiously."

237 *See* final rule 248.30(a)(3). *See also* discussion on covered institutions' required Incident Response Program Including Customer Notification *supra* Section II.A.

238 *See*, *e.g.,* Computershare Comment Letter; Google Comment Letter; ICI Comment Letter.

239 *See* discussion of compliance date *infra* section II.F.

becoming aware of a breach in security has occurred resulting in unauthorized access to a customer information system maintained by the service provider."[240] This modification extends the proposed timeframe for service providers to provide such notice to 72 hours, but maintains the proposed notice triggering event to initiate this timeframe of the service provider becoming aware of a breach."[241]

Commenters addressed both the notification deadline and the triggering event for notifications to be provided by service providers to covered institutions in the event of a relevant breach involving unauthorized access to a customer information system maintained by the service provider. As to the notification deadline, one commenter supported requiring service providers to notify a covered institution within 48 hours of a breach impacting the covered institution or affected individuals, stating its understanding is that this is "not an uncommon arrangement" today between covered institutions and service providers maintaining their nonpublic personal information (e.g., between investment companies and transfer agents).[242] Another commenter raised concerns that a standard of "as soon as possible, but no later than 48 hours after becoming aware of a breach," when paired with a written contract requirement, might impose formidable challenges to covered institutions in mandating such contractual provisions with service providers who are not explicitly subject to Commission jurisdiction, and may have their own policies and procedures addressing breaches.[243] Several commenters suggested the

---

240 *See* final rule 248.30(a)(5)(i). In the proposed rule, such notice would have been required "as soon as possible, but no later than 48 hours after becoming aware of a breach, in the event of any breach in security resulting in unauthorized access to a customer information system maintained by the service provider." *See* proposed rule 248.30(a)(5)(i).

241 *See* Proposing Release at section II.A.3.

242 *See* ICI Comment Letter.

243 *See* Computershare Comment Letter.

Commission adopt a 72-hour notification deadline.[244] In particular, one such commenter stated that this notification provision should be extended to "as soon as possible but no later than 72 hours," to harmonize the Commission's standard with a number of related Federal, State, and international regulatory deadlines governing required service provider notification to financial institutions in the event of a cyber incident, and also further the White House's and Congress's express policy of harmonizing cyber incident reporting requirements.[245] Finally, this commenter stated that a consistent 72-hour reporting deadline would promote more effective cybersecurity incident response and cyber threat information sharing than shorter, or varied reporting periods, and that a 48-hour deadline in the commenter's experience would lead to "premature reporting" that increases the likelihood of reporting inaccurate or incomplete information and tends to create confusion and uncertainty.[246]

In contrast, some commenters recommended modifying the proposal to remove any specified duration for a reporting deadline.[247] Several commenters suggested that rather than an inflexible time deadline, the Commission should require that notification be provided without

---

244 *See* Letter from Microsoft Corporation (June 5, 2023) ("Microsoft Comment Letter"); AWS Comment Letter (this commenter "encourage[d] the Commission" to consider a longer reporting deadline than 48 hours to "support the dedication of resources needed to discover and mitigate potential harm caused by an incident," and highlighted the 72-hour reporting timeframe that "CIRCIA contemplates…for national critical infrastructure, including the financial services sector" in the alternative.).

245 *See* Microsoft Comment Letter (explaining that use of this 72-hour reporting deadline would align the SEC's rules with other notification requirements that may apply to entities covered by the Proposed Rules, and identifying additional authorities that use the 72-hour deadline, such as the CIRCIA, Pub. L. No. 117-103, 136 Stat. 49 (2022); Executive Order 14028, "Improving the Nation's Cybersecurity," 86 FR 26,633 (May 12, 2021), directing the Federal government to incorporate a 72-hour reporting period into the Federal Acquisition Regulation ("FAR"); the Defense Federal Acquisition Regulation Supplement ("DFARS"), 48 CFR 204.7302(b) and 252.204-7012(c); the New York State Department of Financial Services' ("NYDFS") Cybersecurity Requirements for Financial Service Companies, 23 NYCRR § 500.17(a); the European Union's General Data Protection Regulation ("GDPR"), Regulation (EU) 2016/679; and Article 23 of the EU's new Network and Information Security Directive ("NIS 2 Directive"), Directive (EU) 2022/2555).

246 *Id*.

247 *See, e.g.*, Schulte Comment Letter; SIFMA Comment Letter 2.

unreasonable delay after a reasonable investigation has been performed by the service provider.[248] Another commenter stated that rather than mandating any form of a deadline, the time period should be left to covered institutions and service providers to negotiate, accounting for the nature of services and customer data.[249]

As to the triggering event requiring service providers to notify covered institutions of a relevant breach, one commenter urged the Commission to shift from the service provider "becoming aware" of a breach that entailed unauthorized access to customer information, to the service provider "determining" that such a breach had occurred.[250] This commenter asserted that the process of "becoming aware" will involve time and resources to investigate and that changing to a "determining" standard may minimize pressure on the service provider to report prior to performing sufficient investigation, while helping harmonize regulatory approaches across the financial sector, as it would align with similar requirements adopted by Federal banking agencies related to notice provided by bank service providers.[251] Another commenter stated the Commission should, in addition to shifting to a 72-hour reporting deadline, amend the

---

248 *See*, *e.g.,* SIFMA Comment Letter 2 (stating this modification would harmonize with the Proposed Interagency Guidance on Third-Party Relationships: Risk Management, 86 FR 38182, 38184 (proposed July 19, 2021)); ACLI Comment Letter (stating this modification would harmonize service provider and covered entity requirements); and Federated Comment Letter.

249 *See* Schulte Comment Letter. This commenter stated that by mandating a 48-hour limit, service providers would be "left with the impractical challenge of allocating resources to making disclosures to counterparties (i) when resources could be better allocated to identifying and containing the scope of the data breach, and (ii) before the service provider has a complete picture of the impact of a data breach." *See id.*

250 *See* Google Comment Letter.

251 *See* Google Comment Letter (referencing Computer-Security Incident Notification Requirements for Banking Organizations and Their Bank Service Providers, *available at*: fdic.gov/news/board-matters/2021/2021-11-17-notational-fr.pdf?source=govdelivery&utm_medium=email&utm_source=govdelivery).